

Corrigé de l'exercice — RGPD en PME

Exemple complet pour 3 outils d'une PME de 8 salariés

Outil	Données personnelles	Accès	Conservation	Base légale	Risque principal	Action prioritaire
CRM	Nom, email, téléphone, adresse, historique d'achats, notes commerciales	Commercial + dirigeant	3 ans après dernier contact	Contrat / intérêt légitime (B2B)	Contacts sans base légale ou conservés trop longtemps	Auditer la base, supprimer les inactifs, ajouter une mention d'information
Logiciel de paie	RIB, salaire, contrat, adresse, numéro de sécurité sociale	Comptable externe + responsable RH	5 ans après départ (obligation légale)	Obligation légale	Accès trop larges, partage par email non sécurisé	Restreindre les accès, utiliser un portail sécurisé pour les échanges
Drive partagé	Devis, factures, CV, contrats, échanges clients	Tous les salariés	Variable, souvent indéfinie	Contrat / obligation légale	Permissions trop ouvertes, conservation excessive	Créer des dossiers, équipe à droits restreints, purger les anciens documents

Réponses aux questions de réflexion

1. Pouvez-vous supprimer facilement les données d'un ancien ?

Si la réponse est non, votre priorité est de :

- Identifier où ces données sont stockées.
- Créer une procédure de suppression standard.
- Désigner une personne en charge des demandes.

2. Vos salariés connaissent-ils les règles sur l'IA ?

Si ce n'est pas le cas :

- Rédigez une charte d'usage interne simple.
- Interdisez explicitement le collage de données personnelles dans les IA en ligne.
- Proposez une alternative locale (Ollama) ou une solution hébergée en France.

3. Avez-vous une procédure en cas de fuite ?

Si ce n'est pas le cas, créez une fiche réflexe avec :

- Qui alerter immédiatement (dirigeant, DPO externe).
- Quelles données sont concernées et combien de personnes.
- Comment évaluer le risque.
- Quand notifier la CNIL ($\leq 72h$) et les personnes concernées.

Points de vigilance

- **Ne pas tout vouloir faire en une semaine.** Priorisez le logiciel de paie et le CRM.
- **La conformité RGPD est un processus, pas un projet.** Planifiez une revue trimestrielle.
- **Documentez chaque décision.** En cas de contrôle, la CNIL valorise la démarche et la traçabilité.

Besoin d'aller plus loin ?

Si cet exercice révèle plusieurs situations à risque, un accompagnement structuré peut vous faire gagner plusieurs semaines. L'accompagnement type comprend :

- Cartographie des traitements en 1/2 journée.
- Mise à jour du registre et des procédures.
- Formation de l'équipe aux bonnes pratiques et à l'IA sécurisée.
- Plan d'action personnalisé sur 90 jours.